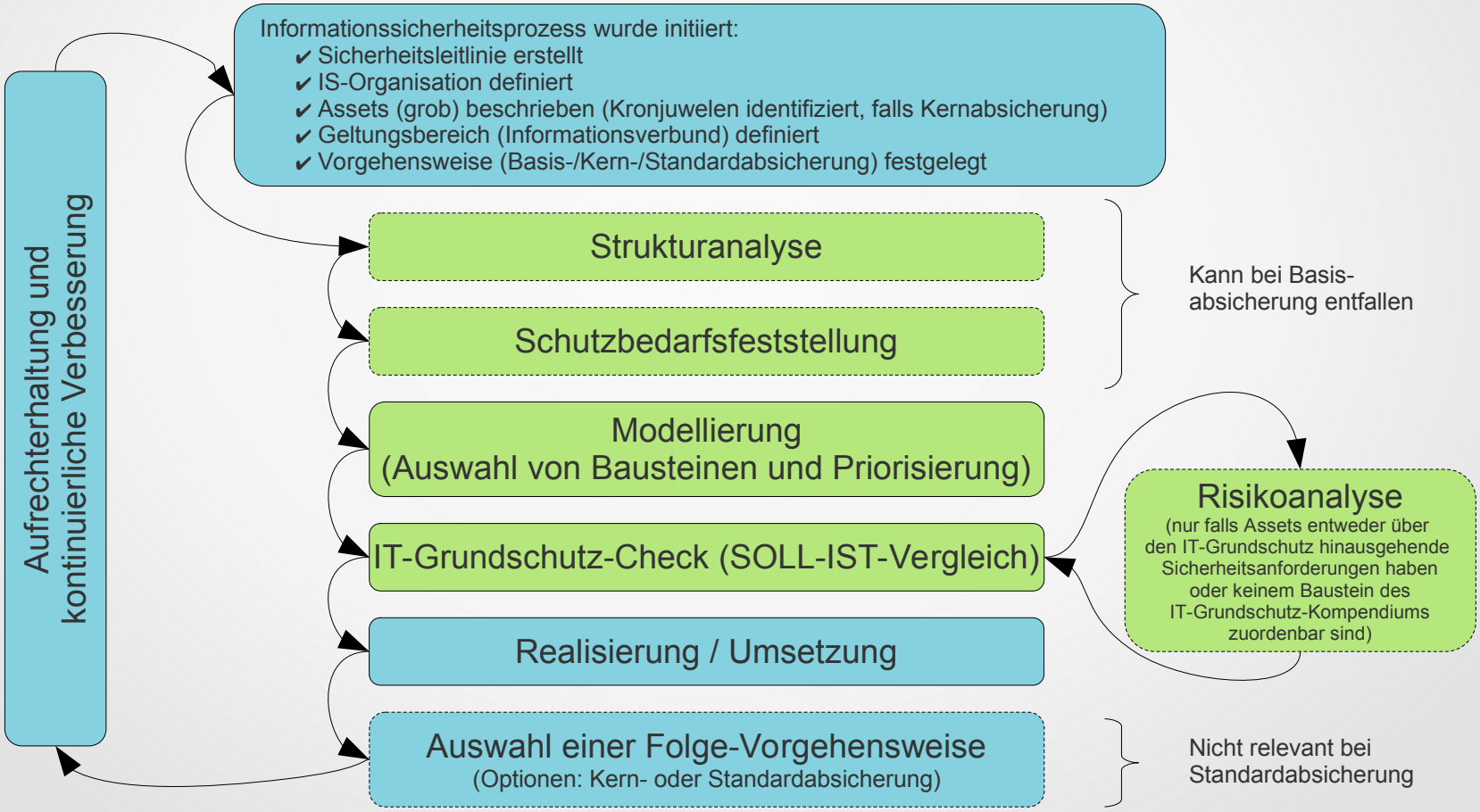
Management der Informationssicherheit

Teil3: Phase 5-6 des Sicherheitsprozesses nach BSI IT-Grundschutzmethodik, Notfall-Management (BSI Standard 100-4)

Informationssicherheitsmanagement

- **IS-Prozess – Phase#4 „Erstellung einer Sicherheitskonzeption“:**



Informationssicherheitsmanagement

- **IS-Prozess – Phase#5 „Umsetzung einer Sicherheitskonzeption“:**
  - Vor Umsetzung einer Sicherheitskonzeption sollte (für den untersuchten Informationsverbund)
    - die Strukturanalyse,
    - die Schutzbedarfsfeststellung und
    - die Modellierung erfolgt und
    - die Ergebnisse des IT-Grundschutz-Checks (Soll-Ist-Vergleich inkl einer möglichen Risikoanalyse) vorliegen
  - Zu vielen Bausteinen des IT-Grundschutzes existieren **Umsetzungshinweise** (IT-GSK – Sicherheitsanforderungen der Bausteine zB ISMS.1.A1 korrespondieren dabei direkt mit den Umsetzungsmaßnahmen zB ISMS.1.M1) mit beispielhaften Empfehlungen für Sicherheitsmaßnahmen, mittels derer die Anforderungen der Bausteine umgesetzt werden können
    - Diese basieren auf Best Practices und langjähriger Erfahrung von Experten aus dem Bereich der Informationssicherheit
    - Die Maßnahmen aus den Umsetzungshinweisen sind jedoch nicht als verbindlich zu betrachten, sondern können und sollten durch eigene Maßnahmen ergänzt oder ersetzt werden
  - **Für die Realisierung der Maßnahmen** stehen in der Regel nur **beschränkte Ressourcen** an Geld und Personal zur Verfügung => **effiziente Umsetzung** der vorgesehenen Sicherheitsmaßnahme notwendig

Informationssicherheitsmanagement

- **IS-Prozess – Phase#5 „Umsetzung einer Sicherheitskonzeption“ - Aktionspunkte:**
  - Fehlende oder nur teilweise umgesetzte IT-Grundschutz-Anforderungen sowie ergänzende **Sicherheitsmaßnahmen** in einer Tabelle **zusammenfassen**
  - Sicherheitsmaßnahmen konsolidieren, dh überflüssige Maßnahmen streichen, allgemeine Maßnahmen an die Gegebenheiten anpassen und alle Maßnahmen auf Eignung prüfen
  - Einmalige und wiederkehrende **Kosten** und den **Aufwand** für die umzusetzenden Maßnahmen **ermitteln**
  - Ersatzmaßnahmen für nicht finanzierbare oder nicht leistbare Maßnahmen auflisten
  - **Entscheidung** herbeiführen, welche Ressourcen für die Umsetzung der Maßnahmen eingesetzt werden sollen
  - Gegebenenfalls Restrisiko aufzeigen und Entscheidung der Leitungsebene dazu einholen
  - **Umsetzungsreihenfolge** für die Maßnahmen festlegen, begründen und dokumentieren
  - **Termine** für die Umsetzung festlegen und Verantwortung zuweisen
  - Verlauf der Umsetzung und Einhaltung der Termine **überwachen**
  - Betroffene Mitarbeiter schulen und sensibilisieren

Informationssicherheitsmanagement

- **IS-Prozess – Phase#5 „Umsetzung einer Sicherheitskonzeption“:**

Auszug aus dem Realisierungsplan der RECPLAST GmbH

A.6 Realisierungsplan der RECPLAST GmbH						
Ziel-objekt	**Baustein**	**Anforde-rungstext**	**umzusetzende Maßnahmen**	**Termin-planung**	**Budget**	**Verant-wortlich für die Um-setzung**
S008 – Print--Server	SYS.1.1 Allgemei-ner Server	SYS.1.1.A3 Restriktive Rechtverga-be	In der Rechtevergabe müssen die letzten Gruppenberech-tigungen aufgelöst werden.	Q3 des Jahres	- €	Herr Schmidt (IT-Betrieb)
S008 – Print--Server	SYS.1.1 Allgemei-ner Server	SYS.1.1.A4 Rollentren-nung	Es sind noch nicht für jeden Ad-ministrator separate Benut-zer-Kennungen eingerichtet.	31.07. des Jahres	- €	Herr Schmidt (IT-Betrieb)
S008 – Print--Server	SYS.1.1 Allgemei-ner Server	SYS.1.1.A8 Regelmäßi-ge Datensi-cherung	Die Datensicherungen werden derzeit auf Bändern innerhalb des Serverraumes aufbewahrt. Geplant ist hierzu ein externes Backup-System. Ein Angebot für die Initialisierung liegt be-reits vor (15.000 €). Die Be-triebskosten müssen noch ver-handelt werden.	Q1 Folge-jahr	Anschaf-fung: 15.000 € Betriebs-kosten: noch offen	Frau Meyer (Einkauf)

Informationssicherheitsmanagement

- **IS-Prozess – Phase#6 „Aufrechterhaltung und Verbesserung“:**
  - **Periodische Überprüfung des Informationssicherheitsprozesses** durch:
    - Definition, Dokumentation und Auswertung von **Kennzahlen** (zB Aktualität des Virenschutzes, Anzahl detektierter Schadsoftware, Anzahl der installierten Sicherheitspatches, Dauer der Systemausfälle, Anzahl der durchgeführten Sicherheitsschulungen, usw)
    - Detektion, Dokumentation und Auswertung von Sicherheitsvorfällen
    - Durchführung von Übungen und Tests zur **Simulation von Sicherheitsvorfällen** und Dokumentation der Ergebnisse (z. B. Back-up-Wiederherstellung)
    - interne und externe **Audits**, Datenschutzkontrollen
    - **Zertifizierung** nach festgelegten Sicherheitskriterien (z. B. ISO 27001 auf Basis von IT-Grundschutz)
  - **Verzahnung der Prozesse** im IS-Management mit Projektmanagement, Change-Management, Incident-Management und Facility-Management um Sicherheitslücken/-mängel schon bei der Planung auszuschließen bzw zu minimieren

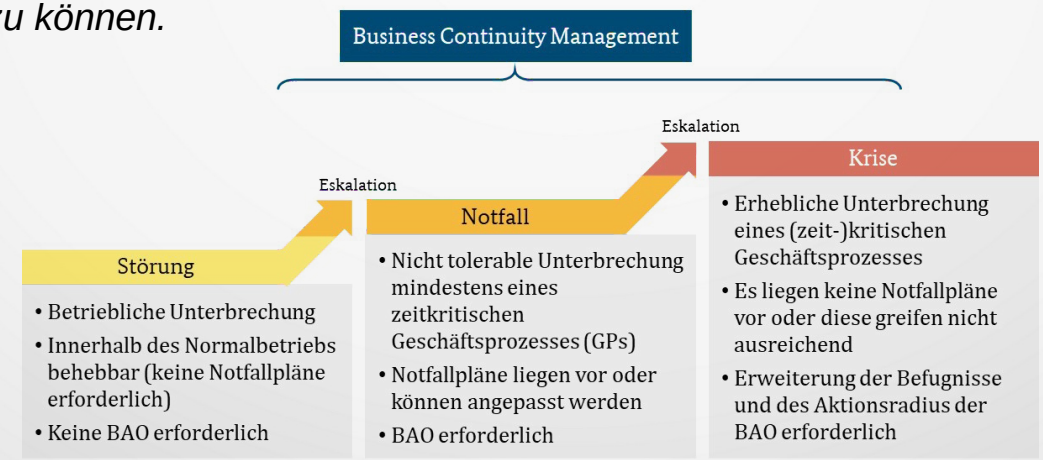
Informationssicherheitsmanagement

- **IS-Prozess – Phase#6 „Aufrechterhaltung und Verbesserung“:**
  - Eignung und **Aktualität von Sicherheitszielen, -strategien und -konzeption prüfen** – vor allem bei
    - betrieblichen Änderungen (zB Einsatz neuer IT-Systeme, Umzug),
    - organisatorische Änderungen (zB Outsourcing) und
    - Änderungen gesetzlicher Anforderungen

    => Anpassung der Sicherheitsleitlinie
  - ggf **Erweiterung der gewählten Vorgehensweise**, dh bspw nach erfolgreicher Basis-Absicherung weiter mit Standard- oder Kern-Absicherung
  - **Angemessenheit** der bereitgestellten Ressourcen und die **Wirtschaftlichkeit** der Sicherheitsstrategie und der -maßnahmen überprüfen
  - Ergebnisse der Überprüfungen in Form von Verbesserungen in den Informationssicherheitsprozess einfließen lassen

Informationssicherheitsmanagement

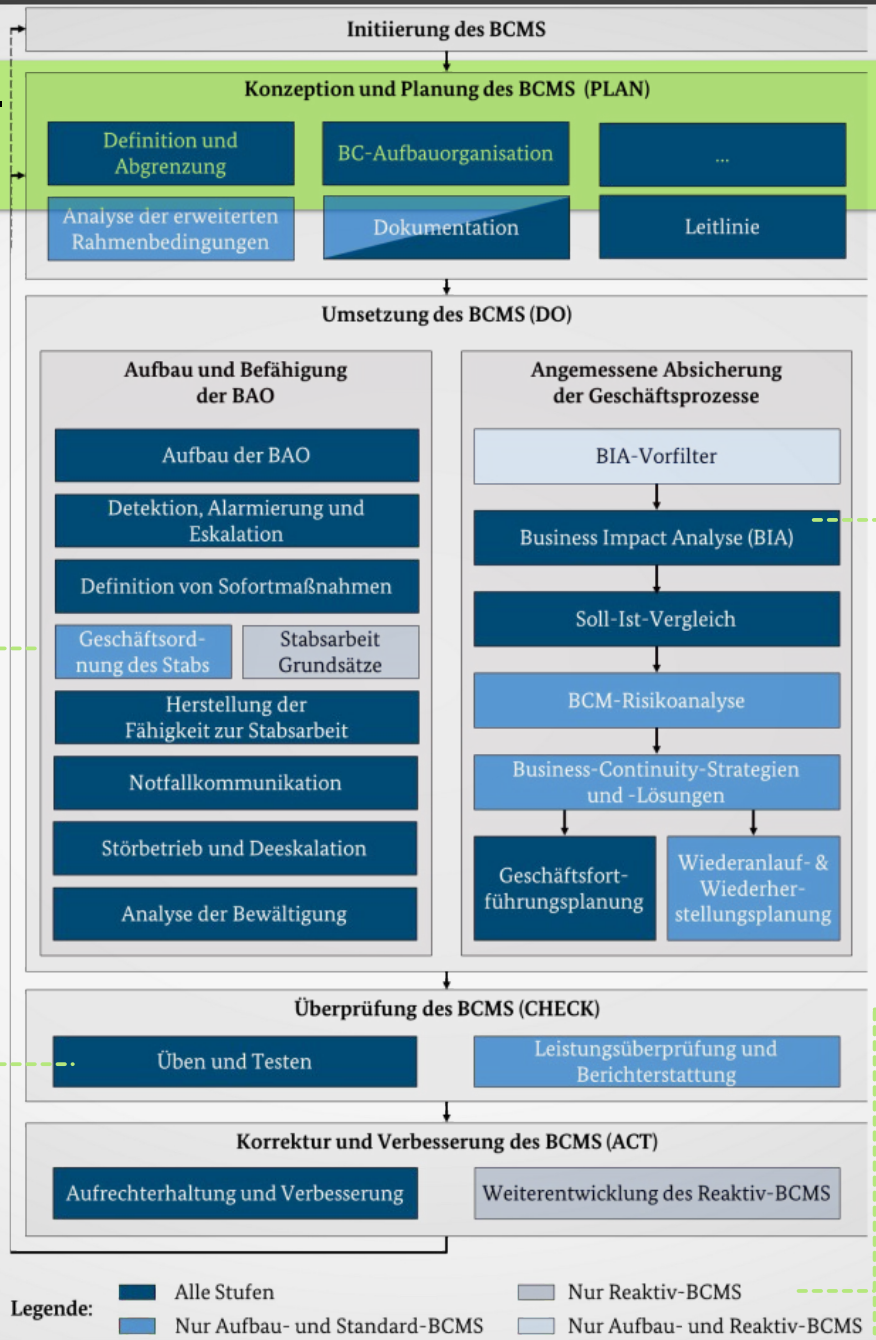
- **Ausblick: Business Continuity Management (BCM, früher: Notfallmanagement) – BSI 200-4**
  - Notfall - Definition: *„Ein Notfall (im Sinne dieses Standards) ist eine (aufgrund des dadurch entstehenden **[sehr] hohen Schadens**[1]) **nicht-tolerable Unterbrechung** des Geschäftsbetriebs, die mindestens einen zeitkritischen Geschäftsprozess betrifft, der **nicht** im Normalbetrieb **innerhalb der maximal tolerierbaren Ausfallzeit wiederhergestellt** werden kann. Im Gegensatz zu Störungen wird zur Bewältigung von Notfällen eine besondere Aufbauorganisation (**BAO**, früher: Notfallbewältigungsorganisation) benötigt. Im Gegensatz zur Krise (=Katastrophe) liegen geeignete Pläne (sog. **Notfallpläne**) zur Bewältigung vor oder bestehende Pläne können adaptiert werden. Der Notfall kann auch ausgerufen werden, bevor das Schadensereignis zu einer Unterbrechung des Geschäftsbetriebs führt, um schnell reagieren zu können.*



[1] lt. einer Studie von Contingency Planning Research (aus dem Jahr 2001!) würde ein einstündiger (!) Ausfall wichtiger IT-Systeme im Durchschnitt folgende Koste verursachen:
-) 108.000 Dollar bei einer Anwendung für Flugreservierungen
-) 3,16 Millionen Dollar bei einer Anwendung für Kreditkartentransaktionen und
-) fast 8 Millionen Dollar im Wertpapierhandel
-) 200.000 Dollar bei Ausfall des App Stores (insgesamt 11h, also 2,2 Mio. Dollar) für Apple 2015 (nicht Teil der oben angesprochenen Studie)

Informationssicherheitsmanagement

- **Übersicht BCM-Prozess (BSI 200-4):**



Wie im Notfall zu reagieren ist (um diesen zu bewältigen), wird im **Notfallhandbuch** dokumentiert. Dieses umfasst u.a. den **Plan für Sofortmaßnahmen**, den **Einsatz der BAO,** die **Notfallkommunikation** und die **Geschäftsfortführungspläne** (alternative Abläufe / Workarounds / Notbetrieb) sowie die **Wiederanlauf- und Wiederherstellungspläne** ([technische] Reparaturen/ Maßnahmen zum Wiederaufbau des Normalbetriebs)**.**

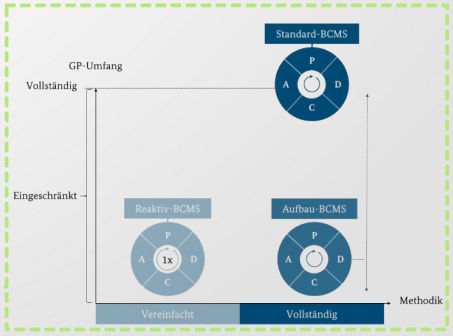
Sämtliche Maßnahmen der Notfallpläne-/handbücher müssen regelmäßig geübt werden. Dazu wird pro **Übung** ein **Drehbuch**, ein **Protokoll**, eine Manöverkritik (**hot wash up**) und ein **Abschlussbericht** erstellt.

Wichtige Schritte bei der Business Impact Analyse (BIA):

Die **Schadensanalyse** untersucht, welchen Schaden der Ausfall einzelner Geschäftsprozesse verursachen kann.

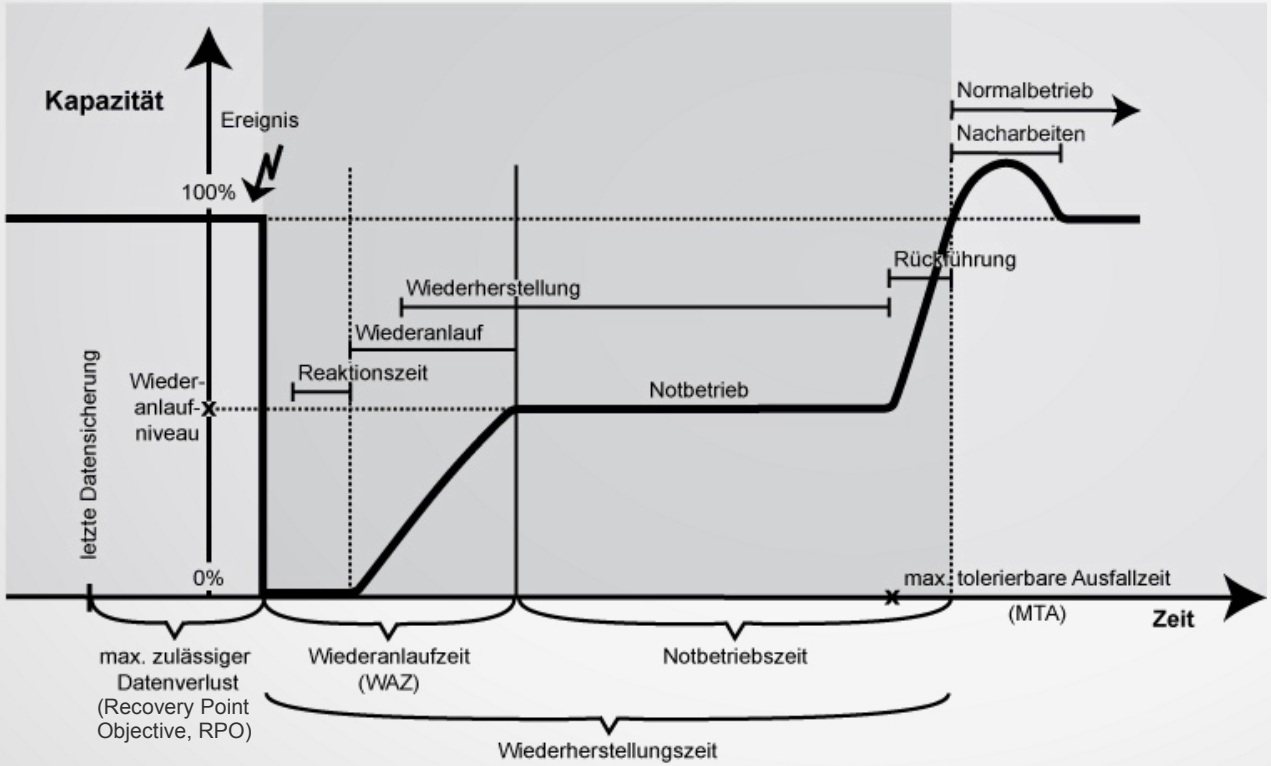
Anhand des zeitlichen Schadenverlaufs und der zu erwartenden Schadenshöhe werden (unter Berücksichtigung von Abhängigkeiten) Wiederanlaufparameter (**maximal tolerierbare Ausfallzeit, Wiederanlaufzeit und -niveau**) für jeden Geschäftsprozess (inkl benötigter Systeme, Räume, etc) festgelegt.

Festlegung der **Kritikalität der Prozesse und Prioritäten für deren Wiederanlauf** auf Basis der Schadensanalyse



Informationssicherheitsmanagement

- **Ausblick: BCM – Wiederanlauf/-herstellung (BSI 200-4)**



Die **maximal tolerierbare Ausfallzeit MTA** (auf englisch Maximum Tolerable Period of Disruption, MTPD) eines Prozesses bezeichnet den Zeitrahmen, in der die Wiederherstellung spätestens erfolgen muss, damit die Institution nicht in eine Phase gerät, in der kurz- oder langfristig ihre Überlebensfähigkeit gefährdet ist.

Die **Wiederanlaufzeit WAZ** (englisch Recovery Time Objective, RTO) ist die angestrebte Zeit, in der der Wiederanlauf des Prozesses erfolgen soll. Die Zeit für den Wiederanlauf WAZ muss kleiner als die maximal tolerierbare Ausfallzeit MTA sein.

Abläufe nach Eintritt eines Notfallereignisses: Innerhalb der Wiederanlaufzeit wird zunächst ein Notbetrieb (mit einer bestimmten Kapazität des Normalbetriebs => Wiederanlaufniveau) hergestellt um das Schadensausmaß in der Zeit bis zur vollständigen Wiederherstellung zu begrenzen.

Informationssicherheitsmanagement

- **Ausblick: BCM – Beispiel Geschäftsfortführungsplan „Ausfall Email-Service“**

IT-Service	BC-Strategie/ BC-Lösung	Gilt für Geschäfts-prozess(e)	RTA/ RTO	RPA/RPO	Maßnahmen, um den Notbetrieb zu erreichen (Wiederanlauf in den Notbetrieb)	Maßnahmen für die Geschäftsfortführung (Notbetrieb)	Maßnahmen zur Rückführung in den Normalbetrieb (Nacharbeiten im Störbetrieb)
E-Mail	*2/Nutzung von Telefon und Fax*	*Alle*	*1 Tag/ < 2 Tage*	*Alle 8 Std./Vor-tageswert (Nacht-sicherung)*	• *Ausweichen auf Telefon, Fax („Workaround“)* • *Vorgefertigte Bandansage auf zentraler Hotlinenummer durch die IT-Abteilung bespielen lassen. Die Bandansage ist an folgender Stelle abgelegt: <Ablageort / Link>* • *Vorgefertigte Information auf Website durch die Öffentlichkeitsarbeit (ÖA)-Abteilung hinterlegen lassen. Die Information ist an folgender Stelle abgelegt: <Ablageort / Link>* • *[…]*	• *Kommunikation erfolgt via alternativer Kommunikationsmittel* • *<Notfallteam A> prüft das Fax und den Anrufbeantworter alle 30 Minuten auf eingehende Nachrichten und leitet diese ggf. weiter* • *Ggf. zusätzliche Kräfte aktivieren, um Arbeitsrückstände zu minimieren* • *Bearbeitete Anfragen dokumentieren. Das vorgefertigte Schema liegt an folgender Stelle ab: <Ablageort / Link zum Dokument>*	• *Wiederhergestellt und ungelesene Emails prüfen* • *Bearbeitete Anfragen mit den wiederhergestellten und ungelesenen Emails abgleichen* • *Zuordenbare und bereits bearbeitete Email-Anfragen löschen* • *Nicht zuordenbare bzw. nicht bearbeitete Anfragen nacharbeiten* • *Arbeitsrückstand ggf. mit zusätzlicher Unterstützung abarbeiten* • *BCM-Koordinator meldet an*

Glossar:

BC: Business Continuity

RTA (Recovery Time Achievable) / RTO (Recovery Time Objective):
Wie schnell Notfall-Lösung betriebsbereit?

RPA (Recovery Point Achievable) / RPO (Recovery Point Objective):
zugesicherter / geforderter Datensicherungszyklus

Quelle: Workshop IT-Notfallplanung, Cybersecurity Day 2025, Bernhard Kux, IHK für München und Oberbayern

Informationssicherheitsmanagement

- **Ausblick: BCM – Optionen für Wiederanlauf/-herstellung (Bsp.)**

Prozess „Rechenzentrumsbetrieb“ MTA = 10 Tage	Wieder-anlauf-zeit	Kosten	Schaden bis zum Wieder-anlauf	Zuverlässigkeit / Randbedingungen / Einschränkungen
S1: Stand-by-Rechenzentrum / „Hot“-Lösung: komplette, redundante IT-Infrastruktur	< 6 Std.	5 Mio. €	gering	sehr hoch
S2: „Warm“-Lösung: eigenes Rechenzentrum; vollständige IT vorhanden; Einspielen von Sicherungen im Notfall notwendig	6-24 Std.	3 Mio. €	gering bis mittel	hoch
S3: „Cold“-Lösung: im Notfall teilweise Beschaffung von Hardware notwendig; Installation der Software und Anwendungen und Einspielen von Sicherungskopien	2-10 Tage	1-1,2 Mio. €	mittel-hoch	Restrisiko: Hardware-Beschaffung; max. WAZ von 10 Tagen entspricht der MTA und damit kein Restpuffer vorhanden.
S4: Dienstleistungsvertrag „Notfall-Rechenzentrum“ mit Dienstleister A	2 Tage	700.000,- €	mittel	Restrisiko: verfügbare Kapazitäten des Dienstleisters im Notfall
		1,3 Mio €	mittel	Vertrag mit Vorrangsbehandlung
S5: Dienstleistungsvertrag „Notfall-Rechenzentrum“ mit Dienstleister B	2 Tage	500.000,- €	mittel	Restrisiko: verfügbare Kapazitäten des Dienstleisters im Notfall; Restrisiko: Zuverlässigkeit und Image des Anbieters nicht ausreichend

Für den Wiederanlauf bzw. die Wiederherstellung gibt es verschiedene Alternativen (auch/vormals: Kontinuitäts-strategien).

Anhand einer Kosten-Nutzen-Analyse kann man diese bspw. evaluieren/ auswählen (s. Beispiel links).